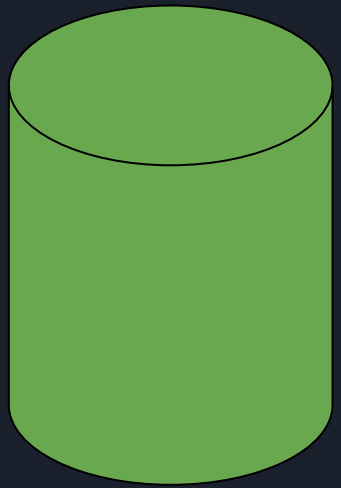
# GESTIÓN DE DATOS

## *ADMINISTRACIÓN: USUARIOS*

# RECORDERIS...



# ¿QUÉ APRENDEREMOS HOY?



- Definición de usuario
- Definición de rol
- Administración de usuarios
  - Creación
  - Borrado
  - Cambio de contraseñas
- Asignación de límites de ejecución

# PARA REFLEXIONAR...

¿Que pasa si en la empresa, todos los empleados utilizan la misma cuenta para acceder a la base de datos?

(discusión verbal)

# PARA REFLEXIONAR...

¿Que pasa si en la empresa, todos los empleados utilizan la misma cuenta para acceder a la base de datos?

- ¿Quién hizo qué y cuándo?
- ¿Quién puede acceder a qué?
- ¿Quién es responsable de qué?
- ¿Desde donde están accediendo a la bd?
- ¿Todos pueden hacer de todo, sin restricción?
- Etc etc etc

# CONCEPTO: Auth-n, auth-z

***Autenticación*: "Demuéstreme que usted es quien dice ser"**

***Autorización*: "Una vez adentro, usted sólo puede hacer esto"**

# DEFINICIÓN: USUARIO

**Es una cuenta que permite conectarse a la base de datos (una persona, una aplicación, un proceso, etc)**

**Se compone por un nombre de usuario (login) más una ip o rango de ip en notación CIDR.**

**Documentación:**
**https://mariadb.com/kb/en/create-user/**

# USUARIOS: ¿Para qué?

- ***Seguridad***: Como acceder (generalmente con usuario y contraseña).
- ***Trazabilidad***: Saber quién hizo qué (especialmente en "post-mortem")
- ***Control de acceso***: Definir límites y permisos
- ***Políticas***: Longitud de contraseñas, periodicidad de cambio, reintentos

En una frase: "***Hay que definir quien ingresa a la bd y como. Y si pasa algo, debe hacer una forma de saber quien fue y como lo hizo***"

# CONCEPTO: Mínimo privilegio

**Así suene obvio, repite conmigo:**

***"Nunca debería darle a un usuario más permisos de los que realmente necesita"***

# CONCEPTO: Usuario ROOT

Los usuarios "root", "sys", "sysdba", "system", "sa" (depende del dbms) tienen ***acceso completo y sin restricciones*** a la base de datos.

CONSEJO DE SEGURIDAD:

***NUNCA USES EL USUARIO ROOT EN UN SISTEMA REAL EN PRODUCCIÓN***

Úsalo sólo cuando sea ***estrictamente necesario***.

Créeme… te vas a evitar lamentaciones más adelante.

# IMPORTANTE!!!

Repite conmigo:

"Debería evitar trabajar con el usuario "root", salvo que sea estrictamente necesario!!!"

"NUNCA debo dejar el usuario root sin contraseña o con contraseñas fáciles de obtener, en bases de datos que estén operando en proyectos reales"



# ¿LO SABÍAS?

Una de las mejores formas de perder el control sobre la base de datos es darle a las personas o a las aplicaciones el usuario root.

Adicionalmente, otra de las mejores formas de perder el control sobre la base de datos es darle a las personas o a las aplicaciones el usuario root.

Por último, por favor, recuerda que una de las mejores formas de perder el control sobre la base de datos es darle a las personas o a las aplicaciones el usuario root.

¿Está claro el mensaje?



# ¿LO SABÍAS?

***NUNCA*** en una base de datos operando en un sistema real en producción, le definas al usuario root contraseñas como "1234", "12345678", "password", "mariadb", "root", "admin", "qwertyuiop", "0000" o similares que sean fáciles de recordar.

Si no me crees, consulta como han sido las formas más comunes de hackeo sobre bases de datos.

¿Está claro el mensaje?



# DEFINICIÓN: ROL

**Es una forma de agrupar permisos y facilitar los movimientos de usuarios entre equipos.**

**Facilita la administración en bases de datos con muchos usuarios.**

**Documentación:**
**https://mariadb.com/kb/en/roles_overview/**

# ROLES: ¿Para qué?

- Administración de grupos, no de usuarios individuales
- Es más fácil administrar un grupo con 100 desarrolladores, que a 100 usuarios que sean desarrolladores
- Facilidad si un usuario cambia de puesto en la organización. Ejemplo: Eliminar un desarrollador del rol de desarrollo y luego asignarlo al rol de DBA
- Si cambia un permiso en el rol, cambia para todos los usuarios de ese rol

# EJEMPLO GRÁFICO



# USUARIOS: Estructura

Un usuario en MySQL o MariaDB es:

login + @ dirección ip de conexión (en formato CIDR)

Ejemplos:

root@%
root@127.0.0.1
root@localhost
test@192.168.1.0/24

test@%
test@127.0.0.1
test@192.168.0.0/24
test@192.168.0.0/16

# USUARIOS: Estructura

La dirección ip en formato CIDR define desde cual IP se debe realizar la conexión.

%: cualquier lugar

localhost: únicamente desde el mismo servidor en el cual se ejecuta la base de datos

172.17.0.1/255.255.255.255: Únicamente desde la ip 172.17.0.1

172.17.0.1/255.255.255.0: subred completa 172.17.0.x con máscara 24

***NOTA: La notación CIDR es un concepto de redes, no de bases de datos. El alcance de este curso no profundiza en este tema, solo lo básico para entendimiento.***

# IMPORTANTE!!!

Repite conmigo:

"Debo evitar crear usuarios con la ip %, salvo que sea estrictamente necesario!!!"



# USUARIOS: Creación

| | |
|---|---|
| Creación "normal", básica | `create user 'selena'@'%' identified by 'selena123';` |
| Con expiración automática de contraseña en 30 días | `create user 'selena' password expire interval 30 day;` |
| Con conexión desde cualquier lugar especificando contraseña en hash (la cual debe generarse primero) | `select password('selena123');`<br><br>`create user selena identified by password '*225BBFE6ABC549D00279B8424B453A46F900F9F5'` |
| Con conexión desde única IP | `create user 'selena'@'172.17.0.1' identified by (...);` |
| Con conexión desde una subred con máscara 24 | `create user 'selena'@'172.17.0.1/255.255.255.0' identified by (...);` |

# USUARIOS: Creación

| | |
|---|---|
| Usando autenticación externa a la base de datos | `create user 'selena' identified via <plugin>`<br><br>NOTA: <plugin> tiene una amplia gama de valores, los más comunes son:<br><br>***mysql_native_password***: Valor por defecto, autenticación directa contra la base de datos<br><br>***pam***: se integra con sistemas tipo LDAP, Directorio Activo, Kerberos, Etc…<br><br>***unix_socket***: Autenticación con usuario del sistema operativo |

# USUARIOS: Creación

**NOTA: Estos son 3 ejemplos de lo que no se debe hacer.**
***Su uso es totalmente desaconsejado en sistemas reales***

| | |
|---|---|
| Con conexión desde cualquier lugar (explícito), sin especificar contraseña | `create user 'selena'@'%';` |
| Con conexión desde cualquier lugar (implícito), sin especificar contraseña | `create user 'selena';` |
| Con conexión desde cualquier lugar (explícito), especificando contraseña en claro | `create user 'selena'@'%' identified by 'selena123';`<br>`(este fue el primer ejemplo presentado, de forma ilustrativa)` |

# USUARIOS: Modificación

| | |
|---|---|
| Modificar contraseña en claro (totalmente desaconsejado) | `alter user selena identified by 'selena456';` |
| Modificar contraseña usando hash | `select password('selena456');`<br><br>`alter user selena identified by password '*CA05827C8ECB76C61DE69C8457356E652F57276B'` |
| Bloquear cuenta | `alter user selena account lock;` |
| Desbloquear cuenta | `alter user selena account unlock;` |

# USUARIOS: Cambio y Borrado

| | |
|---|---|
| Cambiar nombre | `rename user 'selena' to 'selena_gomez';` |
| Eliminar usuario con acceso desde cualquier parte | `drop user selena;`<br><br>`drop user selena@'%';` |
| Eliminar usuario con acceso desde una ip única | `drop user selena@'172.19.0.1';` |
| Eliminar usuario con acceso desde una subred | `drop user selena@'172.19.0.1/255.255.255.0';` |

# ROLES

| | |
|---|---|
| Crear rol | `create role singers;` |
| Eliminar rol | `drop role singers;` |
| Asociar usuario a rol | `grant singers to selena;`<br><br>`grant singers to selena@'172.17.0.1';` |
| Desasociar usuario de rol | `revoke singers from selena;`<br><br>`revoke singers from selena@'172.17.0.1/255.255.255.0';` |

# CONSULTAR

**NOTA: La consulta de usuarios retorna muchos campos. Se recomienda usar un ide, o cambiar el * por la lista de campos que se deseen mostrar.**

**Esta sintaxis funciona en MariaDB y MySQL**

| | |
|---|---|
| Consultar usuarios | `select * from mysql.user;` |
| Consultar roles | `select * from mysql.roles_mapping;` |

# LÍMITES DE EJECUCIÓN

| | |
|---|---|
| max_queries_per_hour | Cantidad máxima de sentencias de cualquier tipo por hora |
| max_updates_per_hour | Cantidad máxima de sentencias tipo "update" por hora |
| max_connections_per_hour | Conexiones máximas por hora |
| max_user_connections | Cantidad de conexiones simultáneas |
| max_statement_time | "Timeout" de cualquier sentencia, en segundos |

**Los límites evitan abuso de operaciones en la base de datos**

# USUARIOS: Modificación

| | |
|---|---|
| Modificar límite de conexiones por hora | `alter user selena with MAX_QUERIES_PER_HOUR 1;` |
| Modificar varios límites al mismo tiempo | `alter user selena with`<br>`MAX_QUERIES_PER_HOUR 10`<br>`MAX_UPDATES_PER_HOUR 10`<br>`MAX_CONNECTIONS_PER_HOUR 10`<br>`MAX_USER_CONNECTIONS 5`<br>`MAX_STATEMENT_TIME 30;` |
| Eliminar un límite | `alter user selena with MAX_QUERIES_PER_HOUR 0;` |

**NOTA: Valores en 0 significan que no hay límites de ejecución.**

# USUARIOS: Session Authorization

Definición:

Ejecutar operaciones como un usuario diferente al de la sesión actual
En algunos DBMS, también funciona a nivel de roles

Objetivos:

- Protección de credenciales de usuarios privilegiados
- Simulación de condiciones de seguridad
- Delegación temporal de permisos (ej: DBA)

# USUARIOS: Session Authorization

| | |
|---|---|
| Modificar usuario de la sesión actual | `set session authorization beckyg@localhost` |
| Retornar al usuario original | `reset session authorization` |
| Otorgar un rol temporal | `set role super_singers` |
| Eliminar rol temporal | `set role none` |

# USUARIOS: Notas adicionales

- Los usuarios y roles se crean a nivel global en la instancia, y no a una base de datos específica (como por ejemplo pasa con las tablas)
- Un usuario puede pertenecer a varios roles
- Es posible (aunque no recomendable) asignar un rol a otro rol
- Los limitantes de ejecución (como MAX_QUERIES_PER_HOUR) deben aplicarse a cada usuario. No aplican para un rol.
- Nativamente, no hay control para cantidad de intentos fallidos en mariadb/mysql

# USUARIOS: Buenas prácticas

- No usar root en sistemas reales en producción (en serio)
- … y mucho menos para una cuenta de una aplicación/backend (más en serio)
- Asignar siempre contraseñas a todas las cuentas (y ojalá contraseñas fuertes)
- Evitar el uso de % en la medida de lo posible
- No compartir cuentas entre varios usuarios (también es muy en serio)
- De nuevo, el principio del mínimo privilegio, siempre

# ENUNCIADO

Se cuenta con el siguiente equipo de trabajo para un proyecto de desarrollo de software:

| Nombre completo | Cargo en el proyecto |
|---|---|
| Albert Einstein | Director del proyecto |
| Leonardo Da Vinci | Desarrollador |
| Isaac Newton | Desarrollador |
| Galileo Galilei | Analista de pruebas |
| Marie Curie | Analista de pruebas |
| Charles Darwin | Analista de pruebas |
| Nikola Tesla | Desarrollador |
| Graham Bell | Analista de negocio |
| Nicolas Copernico | Analista de negocio |
| Michael Faraday | Desarrollador |

# ENUNCIADO

- El área de TI de la empresa ha determinado que el login del usuario corresponde a la primera letra del nombre y luego los apellidos hasta completar 8 caracteres. Ejemplo: Policarpa Salabarrieta sería "psalabar", Manuel Elkin Patarroyo sería "mpatarro", Selena Gomez sería "sgomez" y así sucesivamente.

- Los roles de los integrantes son "developer" para los desarrolladores, "qa" para pruebas y "business" para analistas de negocio.

- Al director del proyecto no le interesa acceder al sistema.

# ENUNCIADO

- La red interna de la empresa usa las direcciones en el rango 192.168.5.0 - 192.168.5.255.

- Los 4 desarrolladores tienen permiso de conectarse desde cualquier parte; los 3 analistas de pruebas sólo desde su propia subred y los 2 analistas de negocio únicamente desde su ip local, las cuales están reservadas para 192.168.5.51 y 192.168.5.52.

- Los desarrolladores no tienen restricciones de ejecución; los analistas de pruebas pueden ejecutar 30 consultas y 40 actualizaciones por hora; tanto los analistas de pruebas como los de negocio pueden tener únicamente 1 conexión abierta a la vez.

# EJERCICIOS

Escribir las sentencias para satisfacer lo enunciado en las diapositivas anteriores.

Recomendaciones:

- Analizar primero la estructura del login y posteriormente las ip de conexión. Con esto ya podrá tener la estructura del usuario
- Posteriormente analizar qué usuarios deben ir en qué roles
- Por último, revisar las restricciones, recordando que son para cada usuario

Una vez tenga analizado lo anterior, le será mucho más fácil escribir el código.

# ¿PREGUNTAS?

